



可信计算池技术 - - 构建浪潮云计算安全基石

浪潮信息安全事业部 蔡一兵 博士

2015.9



目 录



一

云数据中心基础架构安全挑战

二

可信计算技术及产业现状

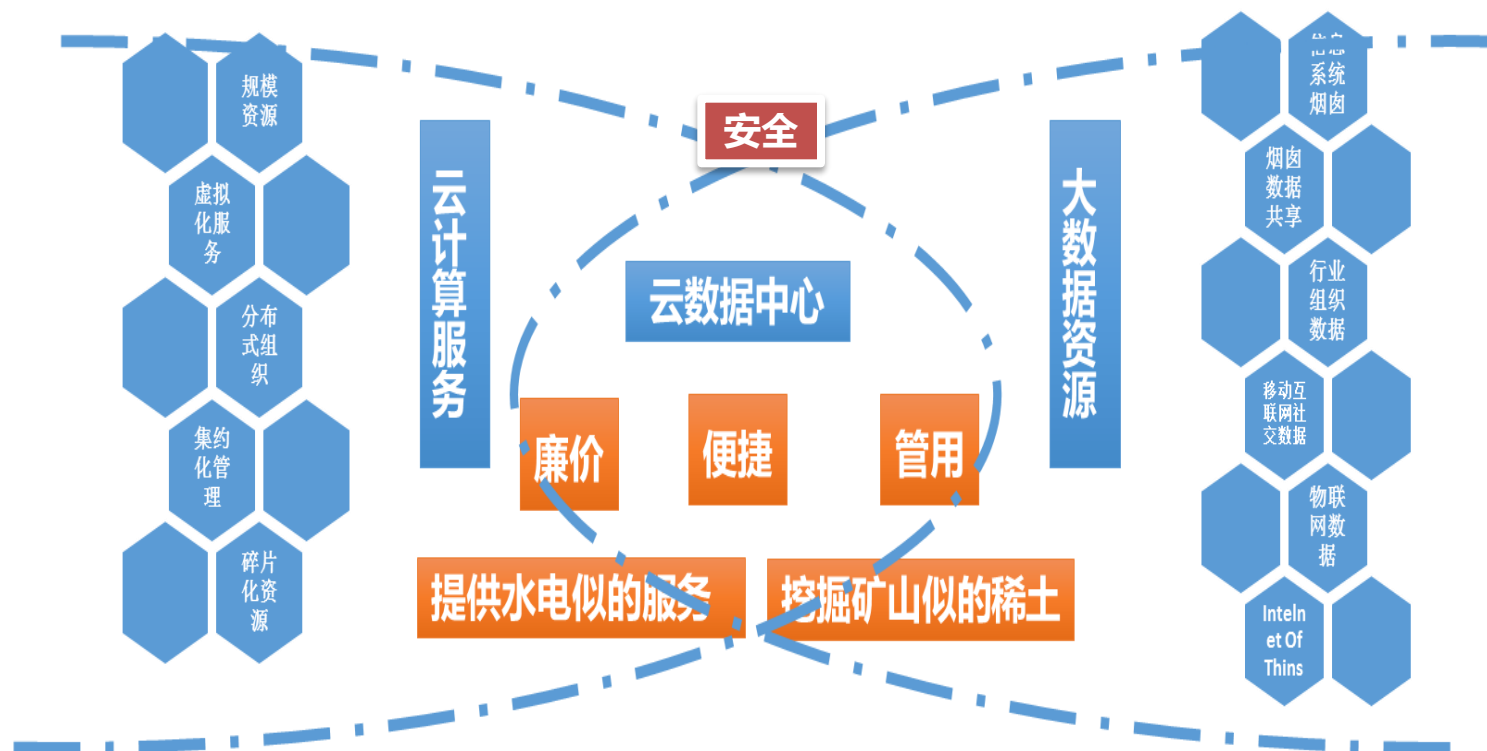
三

可信计算池技术及典型应用

四

浪潮可信计算池工程实践

云数据中心特征



云数据中心

=

云计算服务

+

数据中心

+

大数据资源

外部攻击

- 网络攻击部队
- 网络黑客组织
- 个人职业黑客
- 攻防爱好者



云数据中心正在成为网络空间的战略攻防目标

Tab.1 NSA-IAD' s List-of-Threats to Private-Cloud

威胁领域	威胁内容
硬件	接入恶意设备或植入后门
	内部人员威胁
	供应链风险
固件/BIOS	固件级持久化或关闭设备的攻击
	对 VM 管理器/Hypervisor 的攻击
	VM 补丁更新不及时
	多租户场景下的跨虚拟机攻击
	对存储管理的攻击
操作系统	对操作系统镜像的攻击
	操作系统补丁更新不及时
	对操作系统的攻击以及植入恶意软件
中间件/服务	利用中间件配置问题的攻击
	监控不足以及人工干预
	对存在认证问题的服务的攻击
应用	数据控制问题：缺少保护的文件格式；缺少加密与访问控制
	SQL 注入等针对设计和实现漏洞的攻击
	恶意应用程序（移动、桌面等）
网络基础设施	网络可恢复性问题
	网络隔离控制机制不成熟
	公有云服务将数据带入互联网甚至离境
	对路由器及其它网络设备的攻击
	网络设备供应链风险
	网络设备补丁更新管理不善

NSA-IAD 所列举的安全威胁（见表 1）



NSA私有云安全评估：威胁覆盖从底层硬件、中间虚拟化、上层应用

应用安全威胁

传统安全风险并没有减少

2013年，CNCERT/CC监测发现我国境内**1.5万台主机被APT木马**控制，对我国关键基础设施和重要信息系统安全造成严重威胁



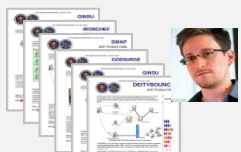
虚拟安全威胁

新技术/应用模式引入的风险

- Rootkit攻击
- 数据隔离
- 数据泄密
- 云OS缺陷
- 虚拟机蔓延
- 网络边界模糊
- 系统崩溃
- 数据丢失
- 服务不可用
- 资源共享风险
- 虚拟机迁移攻击
- API接口风险
- 虚拟化软件缺陷

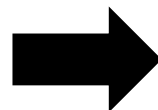
固件安全威胁

“棱镜门”事件后引发的挑战

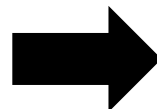


NSA针对计算机固件的攻击工具

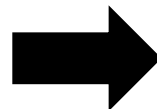
应用攻击
层出不穷



虚拟共享
危害更大



硬件攻防
防护空白



云主机架构

云主机

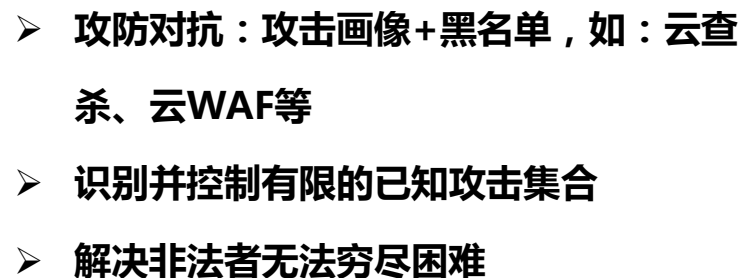


虚拟计算资源服务

计算池



传统安全威胁日益严重，底层硬件APT网络武器威胁以及计算资源虚拟化后带来的新型威胁更加难以应对。



✓ **硬件/虚拟/应用一体**



Roadmap

第一代



第二代



第三代

软件特征	虚拟化	计算、存储虚拟化	计算、存储、网络虚拟化	资源统一调度
	云管理	资源集中管理	软件定义的计算、存储、网络	业务驱动的SDDC
硬件特征	CPU	节点内紧耦合	节点内紧耦合	CPU资源池
	内存			内存资源池
	存储		存储池	存储资源池
	供电	供电模块共享	供电模块共享	供电模块共享
	散热	散热模块共享	散热模块共享	散热模块共享
	网络	节点间以太网连接	机架内高速互连	网络资源池



云计算基础设施演进挑战：

- 传统架构无法满足需求，基于新技术进行架构变革
- 传统安全技术无法应对威胁，基于新安全理念进行云端防御
- 数据中心融合架构 = 硬件重构 + 软件定义 + 主动免疫

- ✓ 业务驱动融合架构
- ✓ 弹性按需计算服务
- ✓ 软件定义数据中心
- ✓ 硬件重构基础设施
- ✓ 主动免疫安全架构

目 录



一

云数据中心基础架构安全挑战

二

可信计算技术及产业现状

三

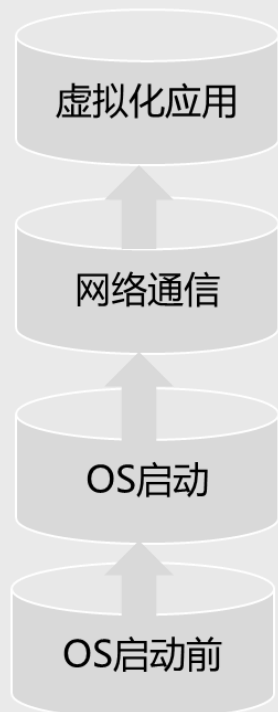
可信计算池技术及典型应用

四

浪潮可信计算池工程实践

可信计算与传统防护措施的对比

系统防护层次



传统防护措施



可信计算体系

体系化和结构化防护

- 信任链从主机扩展到虚拟化层，实现对物理机、虚拟机等可信度量
- 基于可信网络连接的远程终端、用户和平台的身份证明
- 基于芯片的完整性度量实现主动防御，强度更高
- **优先启动防恶意软件主动防护**
- **从系统加电开始建立基于可信芯片的信任链**

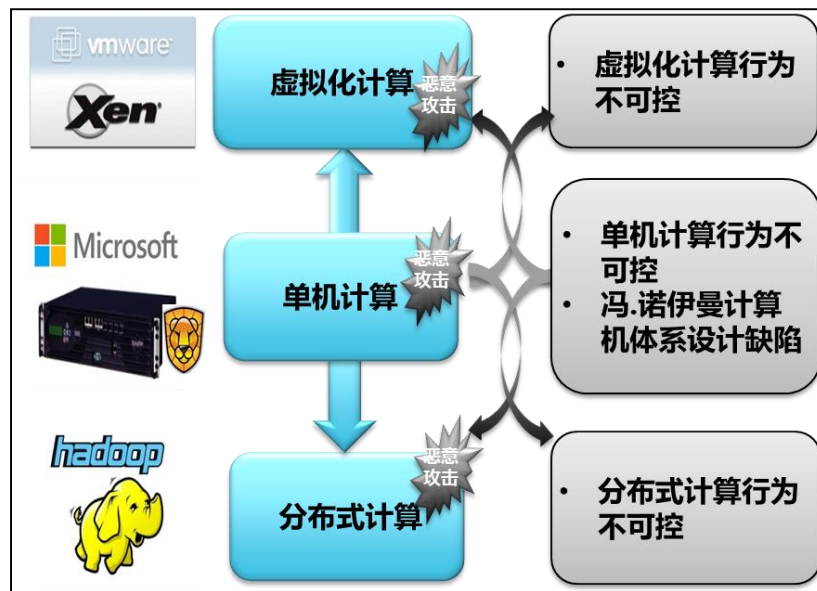
黑安全策略



白安全策略

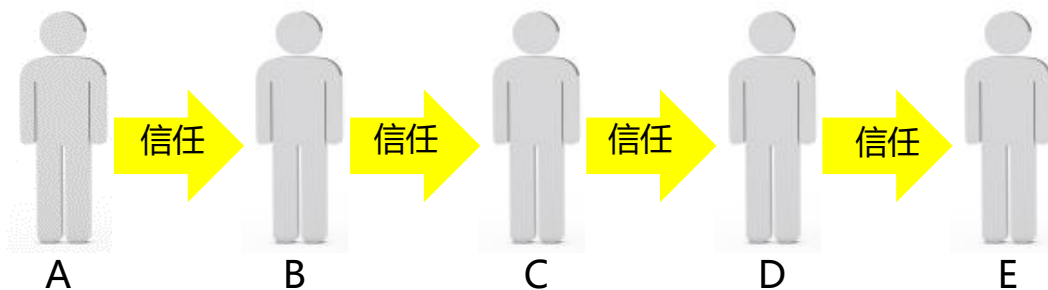
从单机可信到云计算可信

- 从单机可信到云计算可信
- 计算环境完整性保护



- 计算架构安全缺陷，从单机扩散到云主机
- 破坏计算环境完整性，可能是攻击目的，也可能是攻击途径

可信计算技术价值：构建基于计算环境完整性保护的计算免疫能力



- A信任B.....D信任E
- A信任E

计算信任体系

信任链构建

构建信任根->硬件平台->操作系统->上层应用，
一级认证一级，一级信任一级，把这种信任扩展到整个计算机系统。

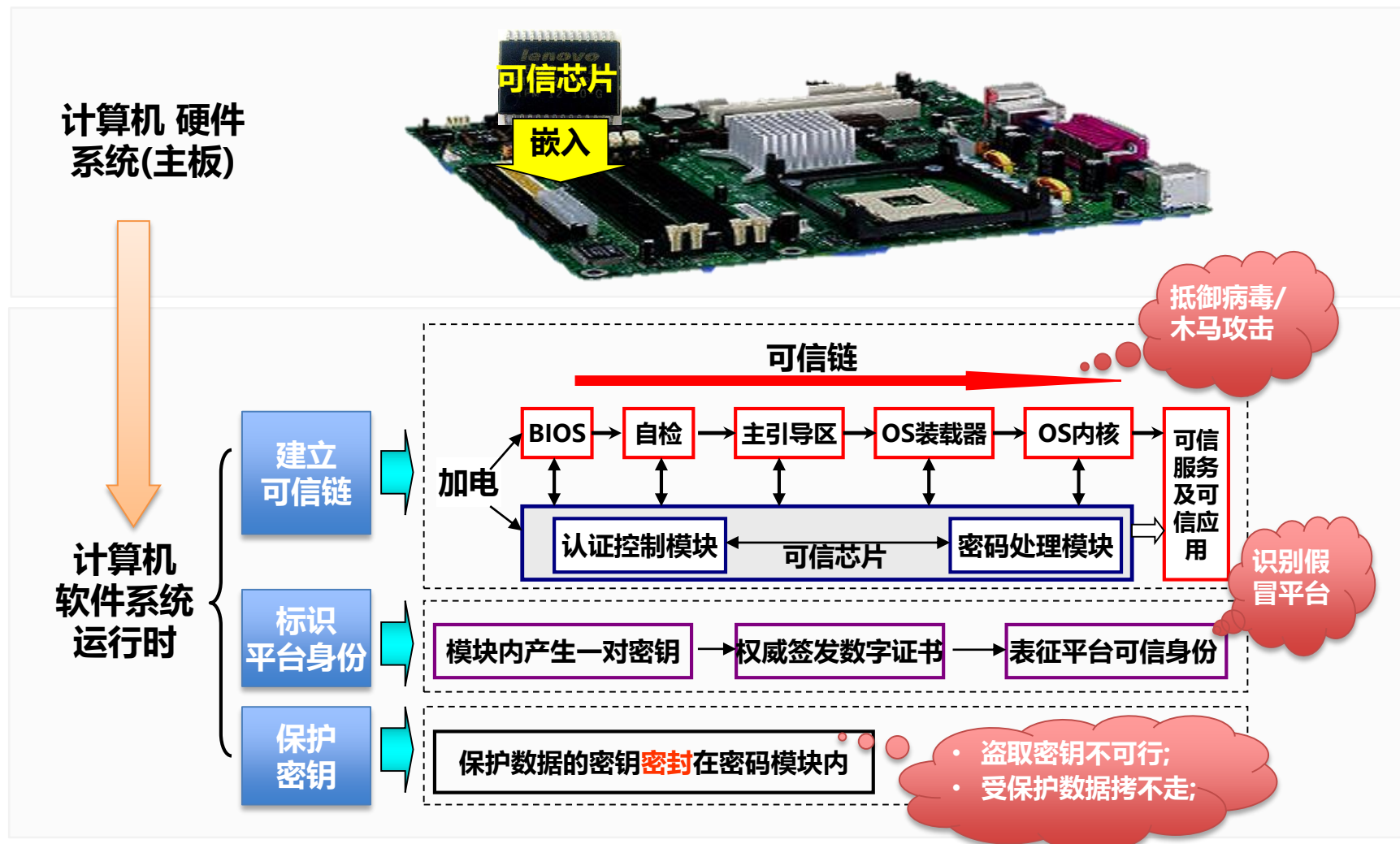
信任度验证

通过密码技术验证各级对象的完整性是否受到篡改，
先完整性度量->后完整性验证

信任根设置

可信芯片--基于硬件芯片物理保护及安全密钥管理机制，
构成计算机信任体系信任根；

可信计算技术理念



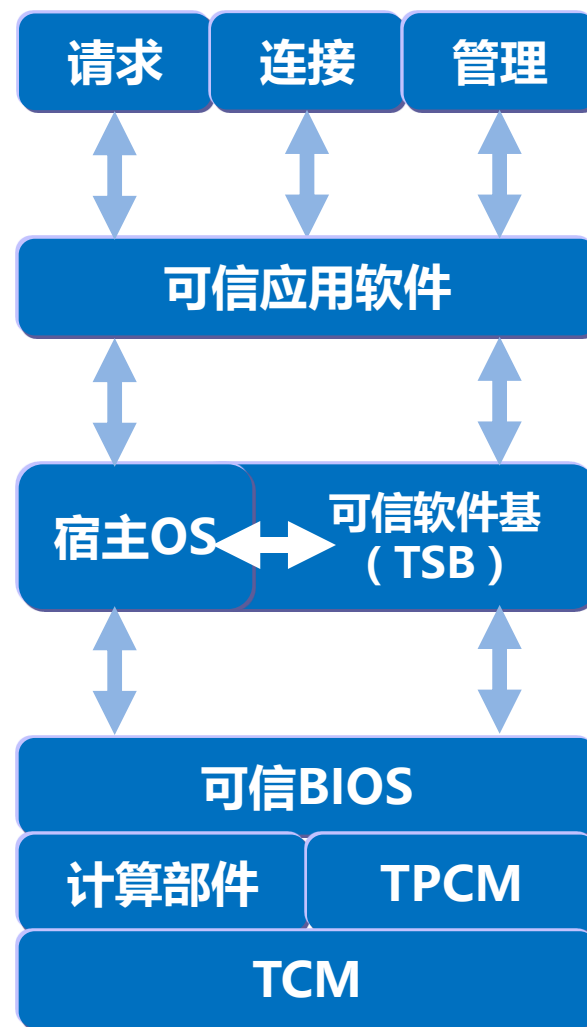
网络层面的**三元三层对等架构**

软件层面的**双系统体系结构**

主板层面的**计算和可信双节点融合**

芯片层面的**主动控制**

可信计算**自主密码方案**



双体系结构

打基础

密码标准：自主密码体系

构主体

四个主体标准：芯片、主板、软件、网络

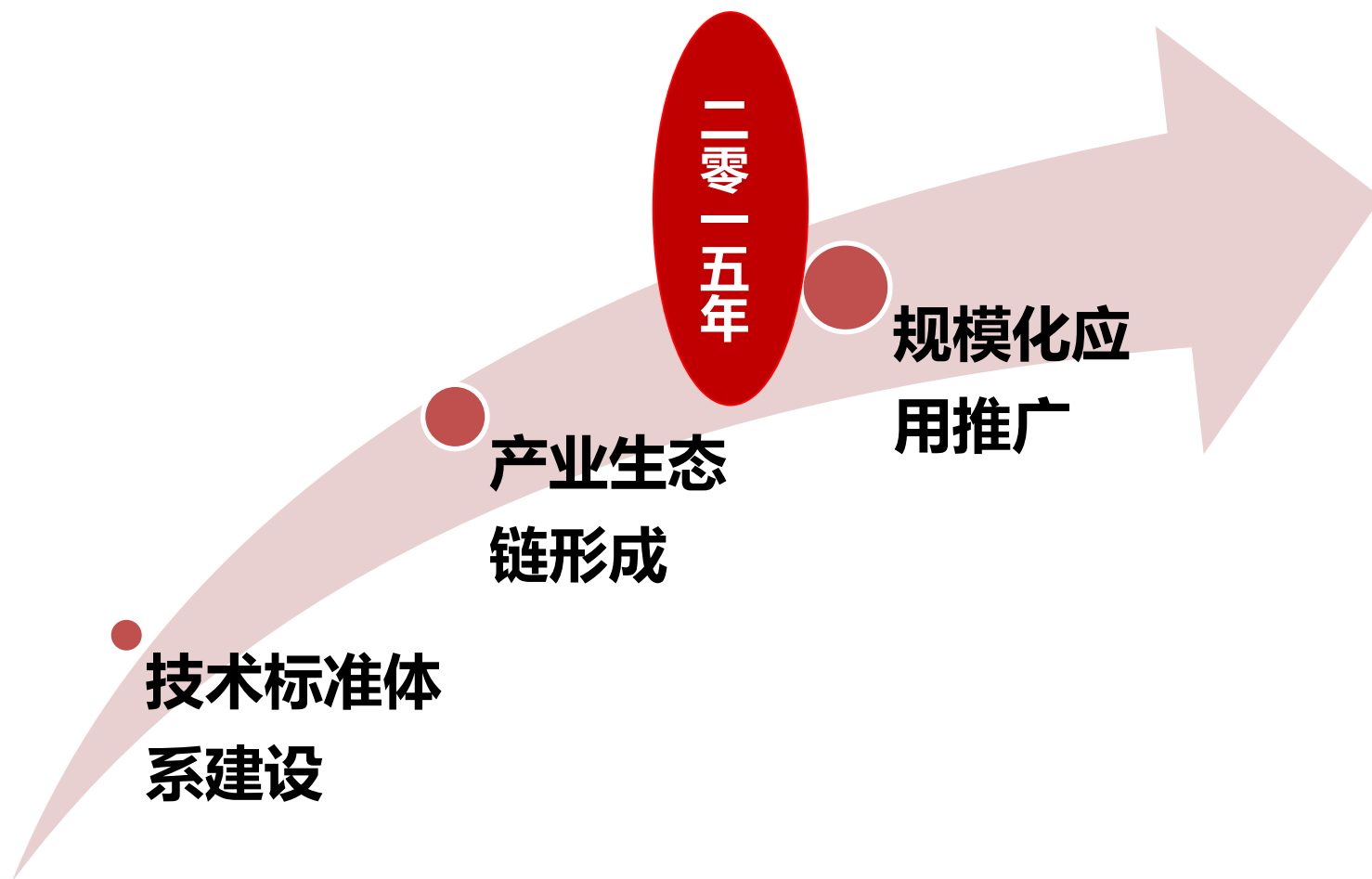
搞配套

四个配套标准：规范结构、服务器、存储、测评

成体系

各种应用相关标准：网站、办公、等保等

可信计算产业发展阶段



中国可信计算产业生态



风险管理
法规遵从

- 国家政策、标准体系
- 信息安全服务

业务应用

- 支持可信计算的行业应用

安全策略管理

- 虚拟机管理程序的策略配置
- 安全可信管理中心

虚拟机管理程序

- 信任链传递到虚拟机
- 虚拟机管理程序的可信启动

服务器/桌面/移动操作系统

- 信任链、可信内核
- 可信软件栈、可信网络连接

服务器/桌面/移动端硬件平台

- BIOS支持
- 提供基础可信平台模块

可信平台模块 (TPM2.0/TCM/TPCM)

- 用于存储的信任根
- 用于报告的信任要

目 录



一

云数据中心基础架构安全挑战

二

可信计算技术及产业现状

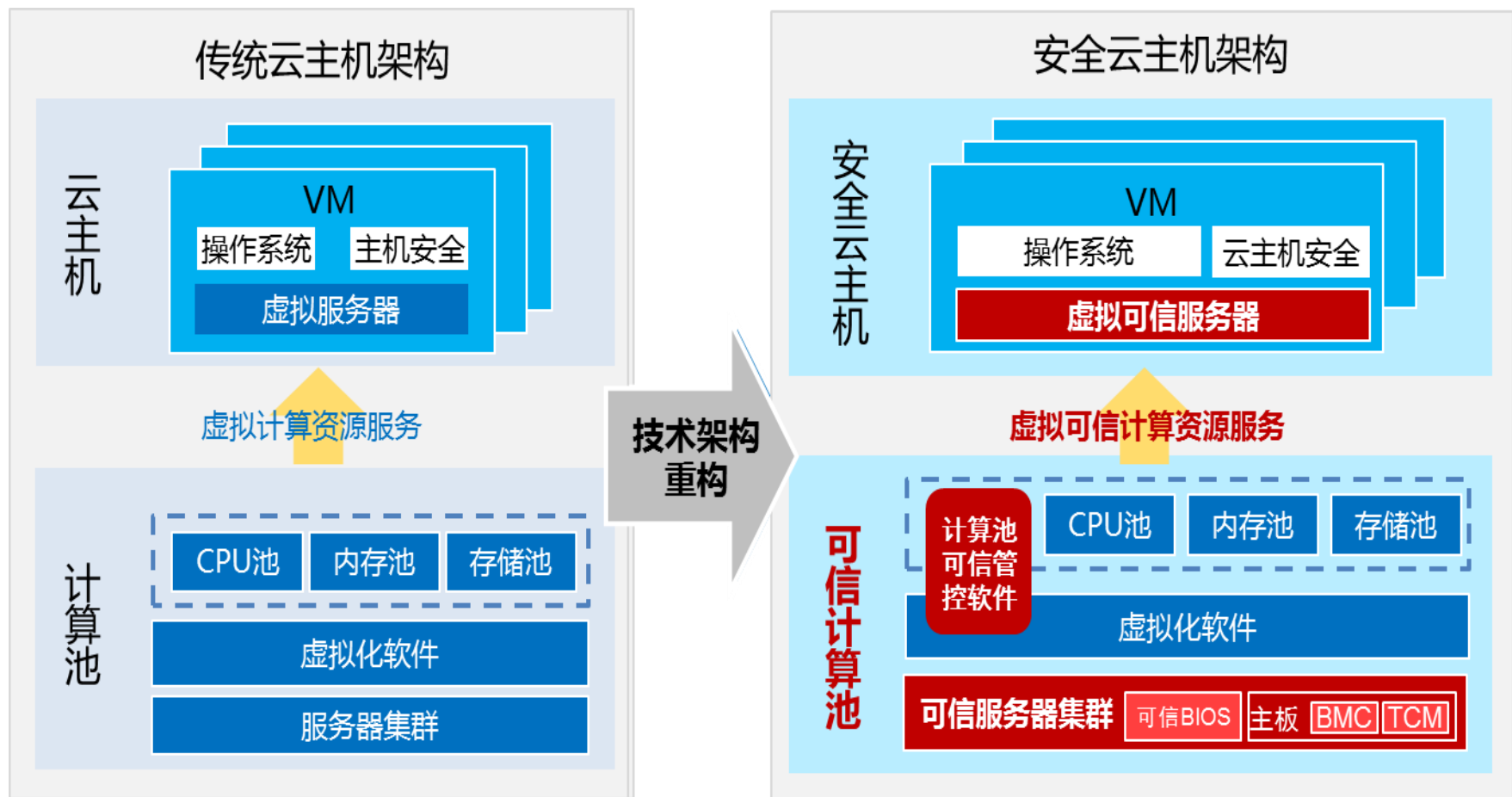
三

可信计算池技术及典型应用

四

浪潮可信计算池工程实践

从计算池到可信计算池



可信计算池系统由可信服务器集群、虚拟化软件和计算池可信管控软件组成，池化管理服务器集群的CPU、内存、硬盘等计算资源，对外按租户要求提供具有可信免疫能力的虚拟可信服务器。

可信的云架构示意图

可信应用

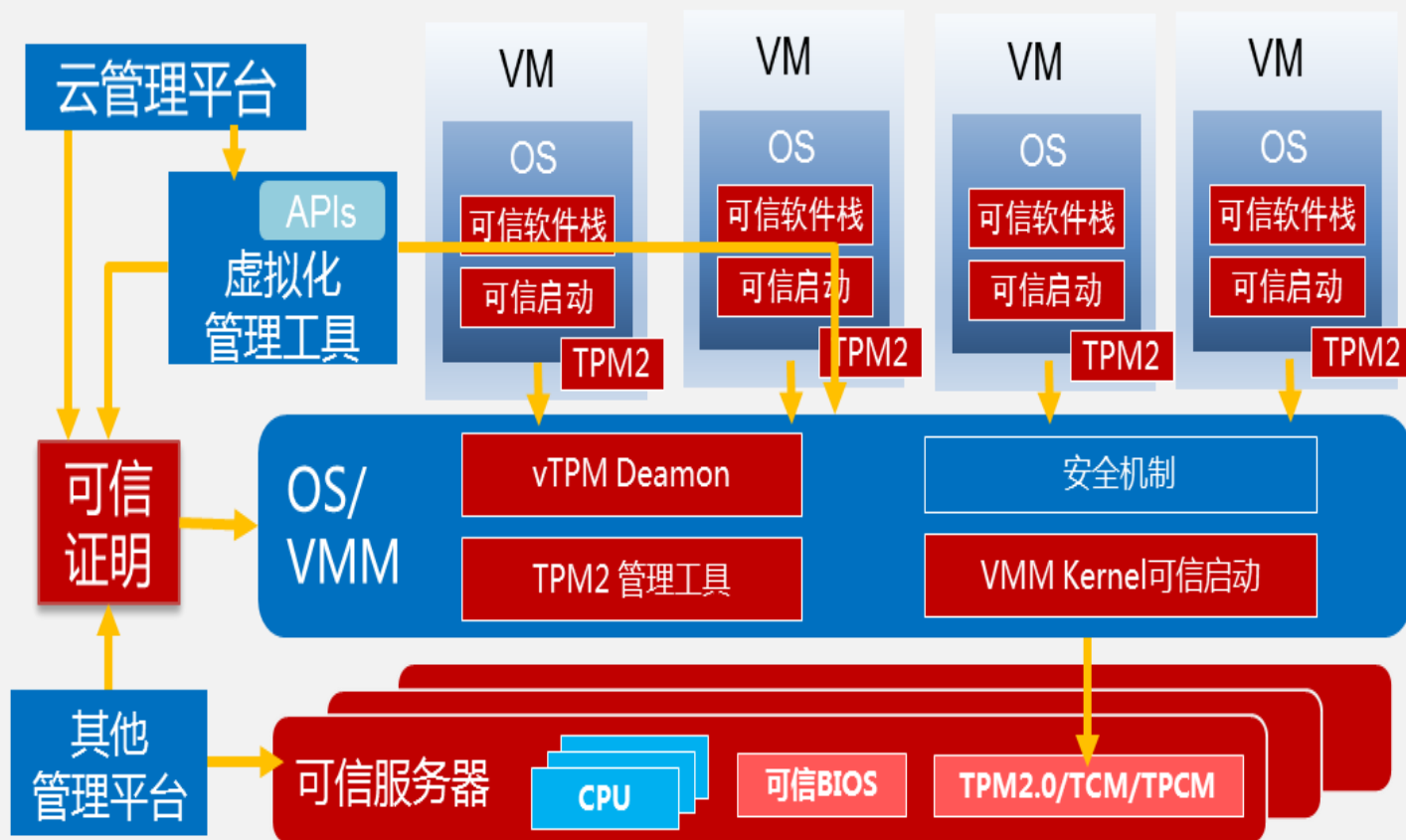
数据位置控制

可信云访问控制

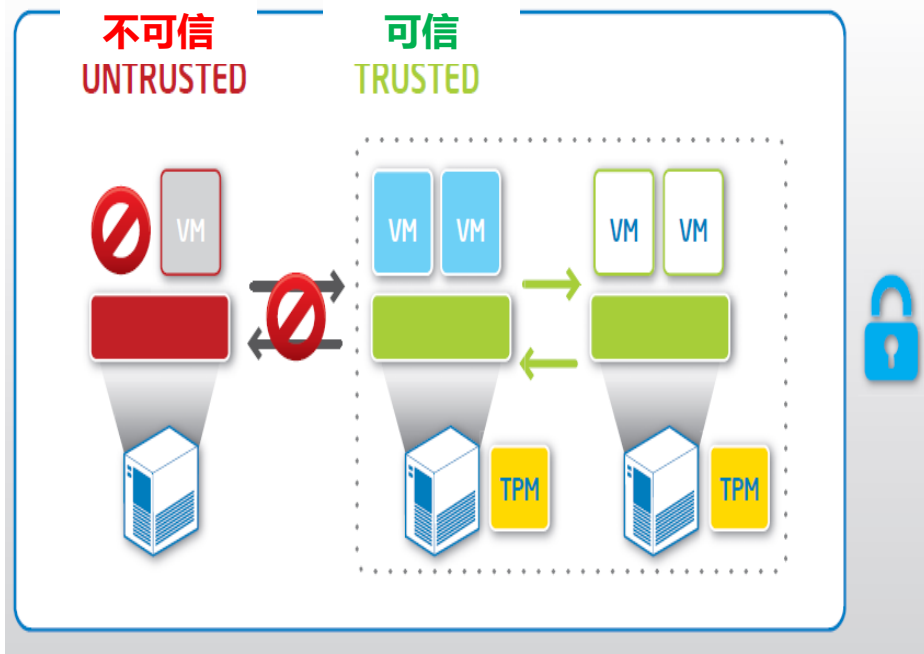
合规性审计

.....

可信计算池



可信计算池



1

检测启动组件，减少恶意软件威胁

2

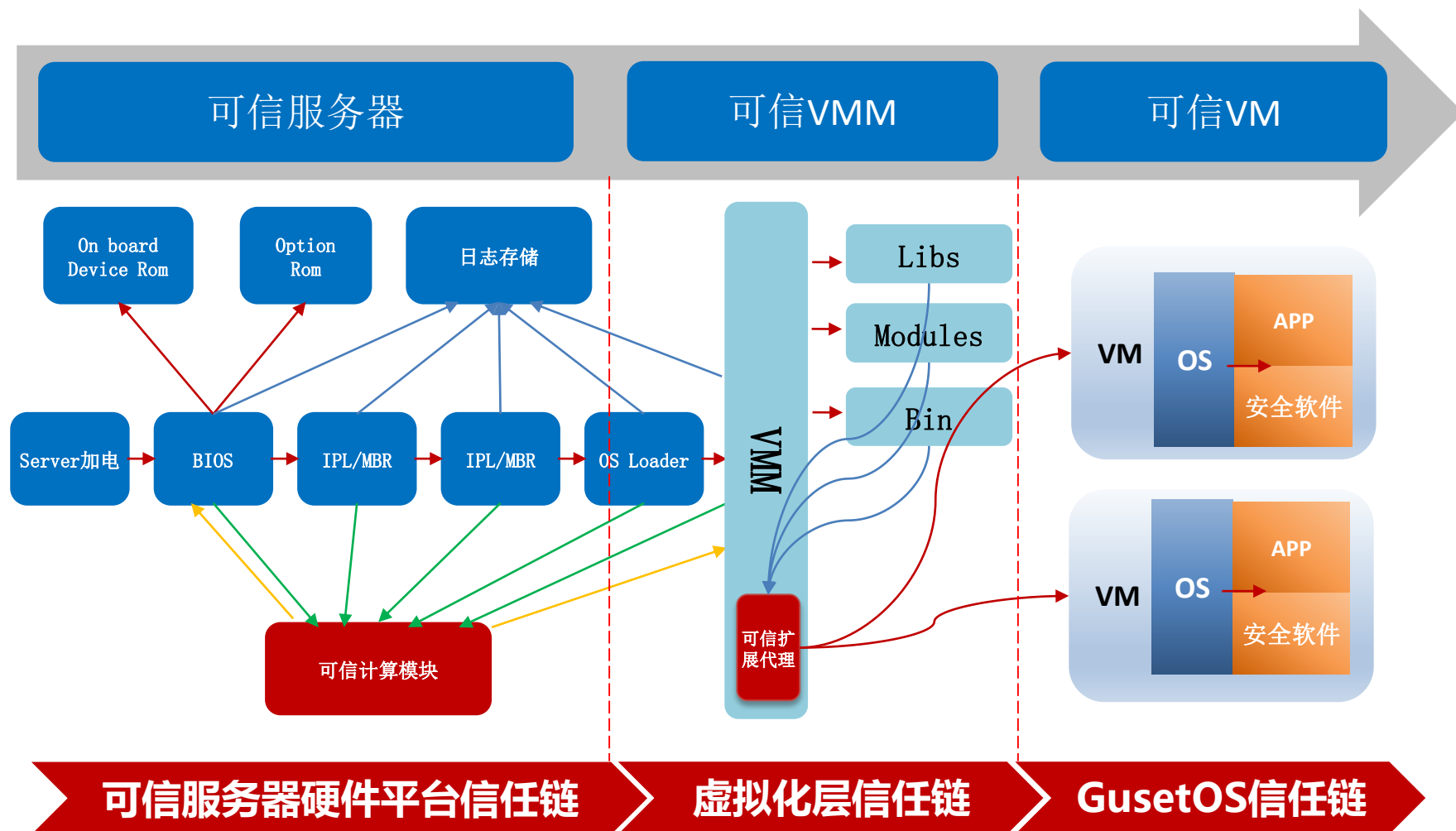
控制基于平台信任（和其他属性）的虚拟机，强化数据保护。

3

针对合规性和可审计性提供硬件支持

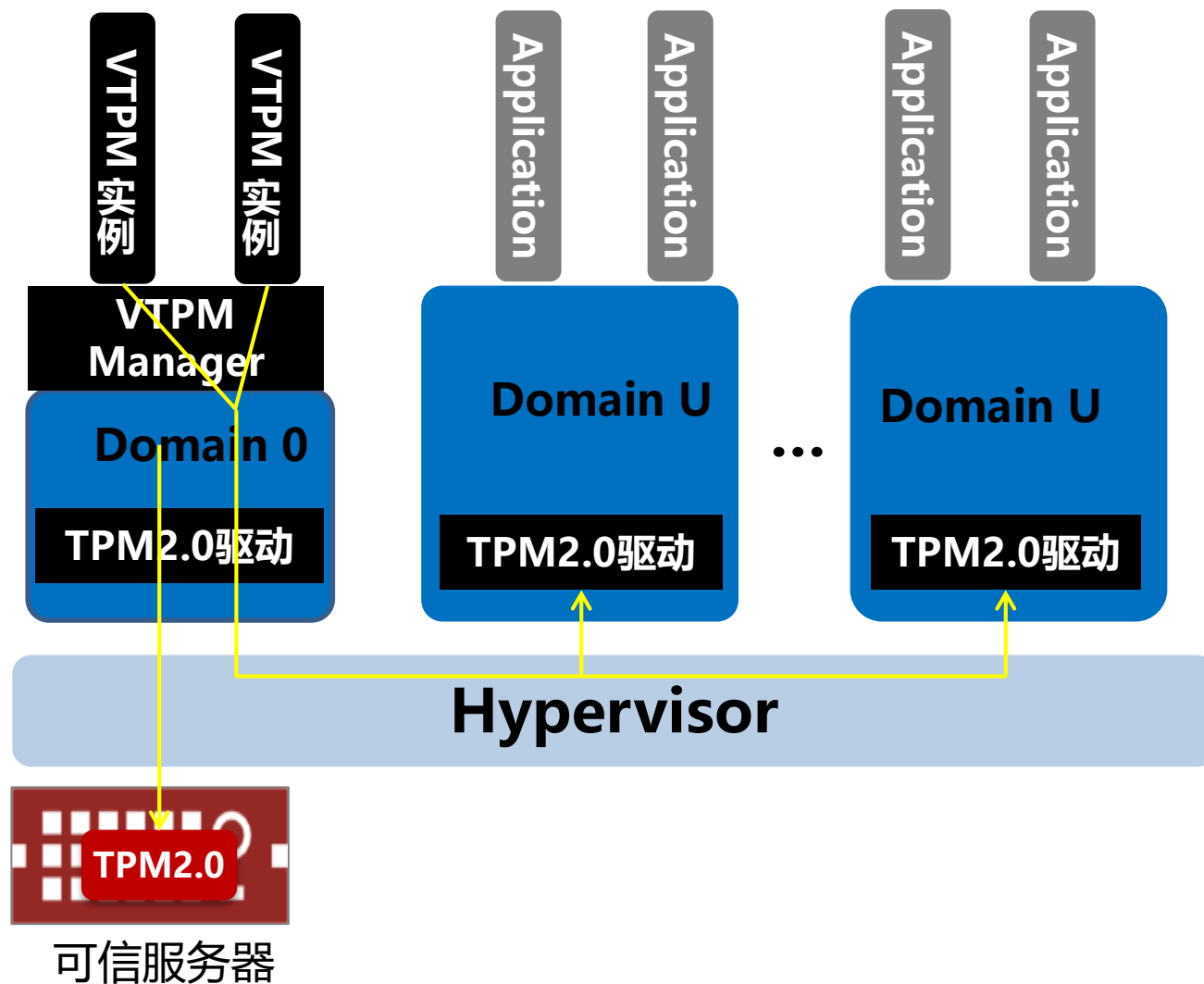
通过构建可信计算池，帮助化解云安全挑战

构建可信计算池的关键技术——信任链

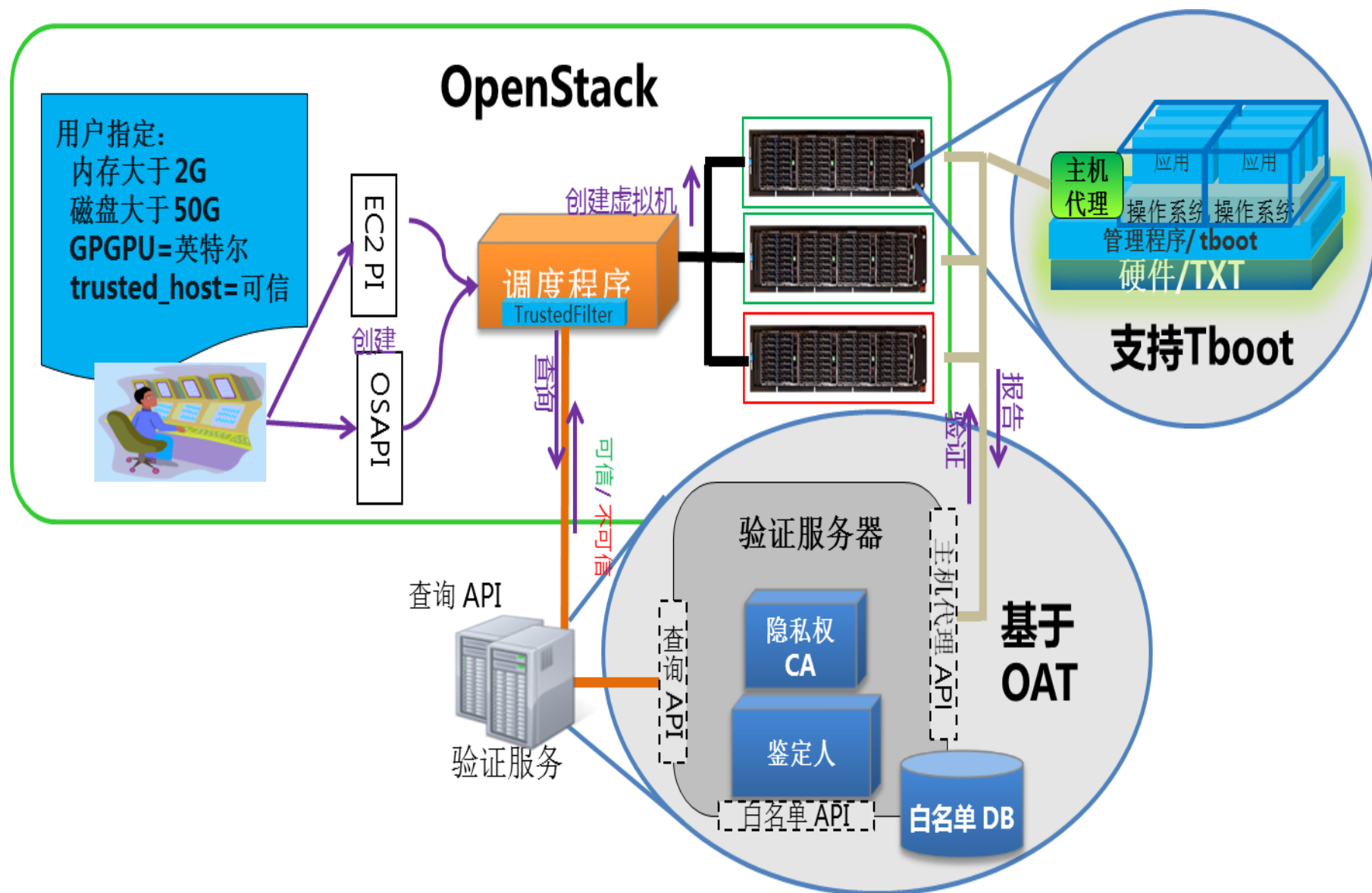


- 解决虚拟计算可信链构建问题，适应大规模、弹性扩展、管理自动化的云计算管理要求，实现从物理服务器可信到虚拟服务器可信。
- 虚拟可信服务器纵向信任链构建、横向迁移可信度量及管理技术。

构建可信计算池的关键技术——vTPM

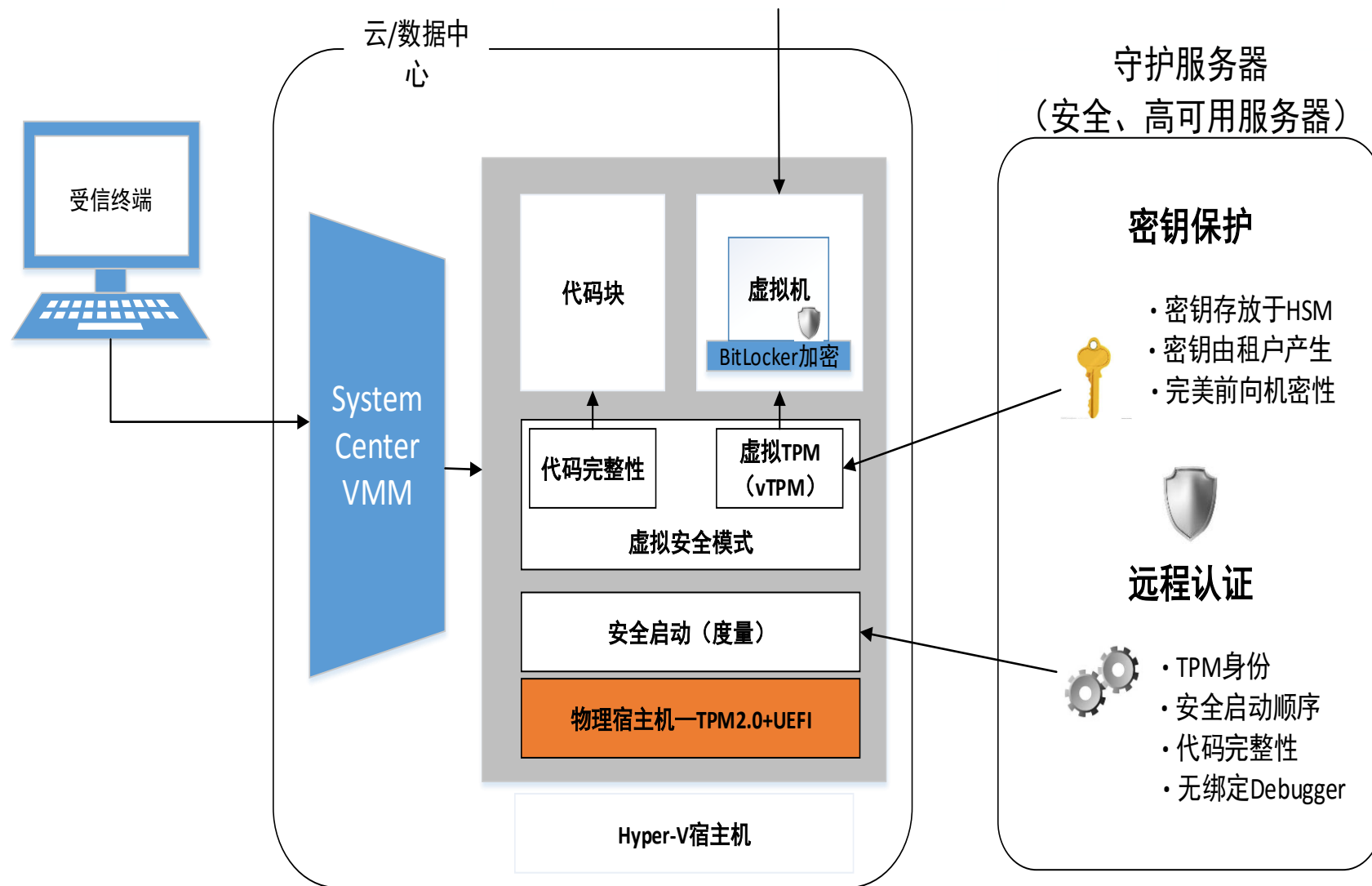


构建可信计算池典型案例——OpenStack、OAT、Xen

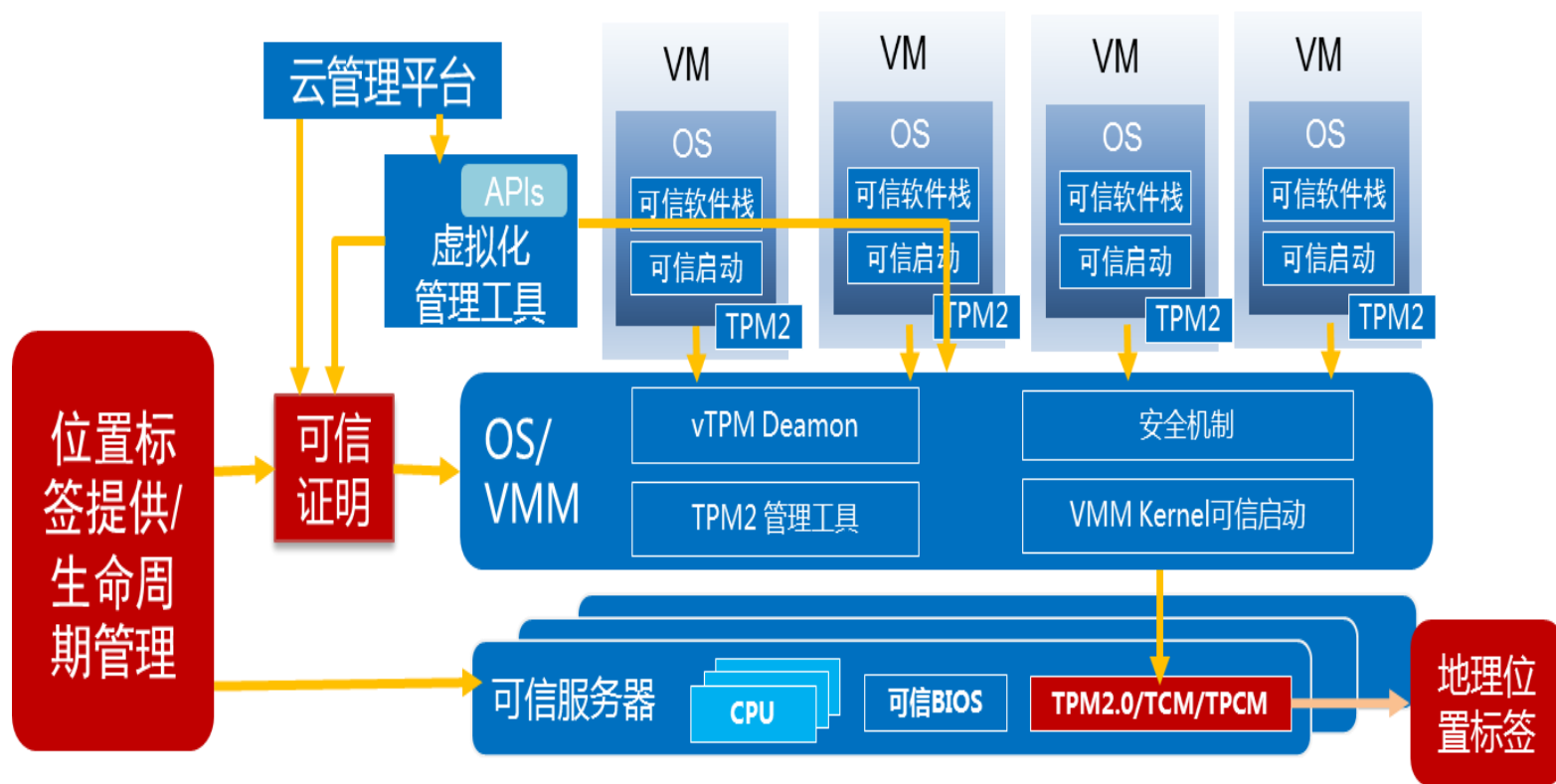


可信计算池典型案例——租户虚拟磁盘加密

受保护的虚拟机—第二代虚拟机

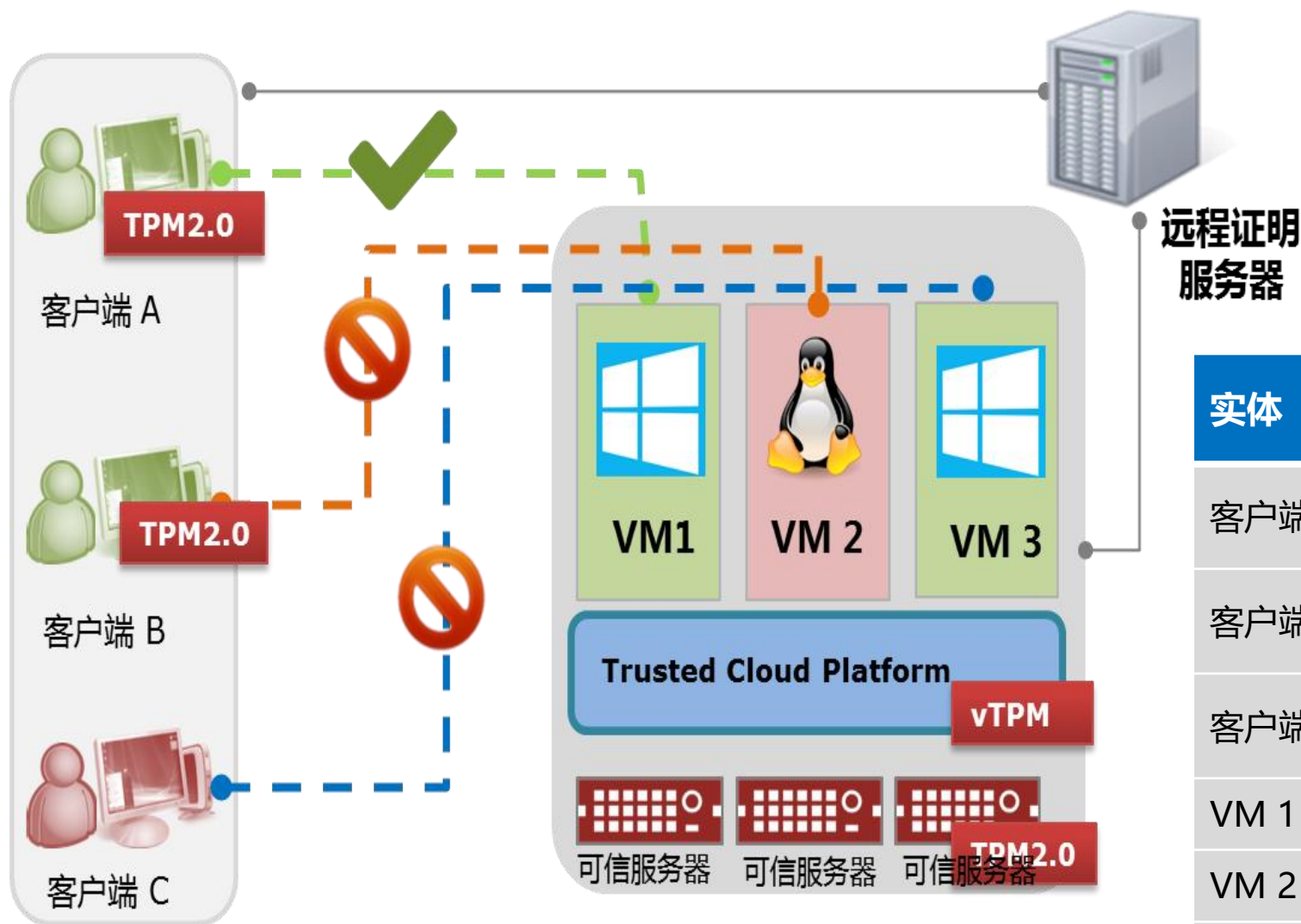


可信计算池典型应用——云环境下数据资产地理位置控制



确保工作任务只能在授权的地理区域上的可信服务器上执行

可信计算池典型应用——客户端可信云访问控制



实体	信任状态
客户端 A	可信
客户端 B	可信
客户端 C	未知
VM 1	可信
VM 2	不可信
VM 3	可信

目 录



一

云数据中心基础架构安全挑战

二

可信计算技术及产业现状

三

可信计算池技术及典型应用

四

浪潮可信计算池工程实践

浪潮云计算安全可信解决方案V2.0 (2015年)



(一) SSR

- 私有云的政府/央企客户
- 企业级主机安全解决方案

(二) 云戟

- 公有云的小微客户
- 免费网站安全解决方案

(三) 商用可信服务器

- 支持国产密码算法，防御硬件层面APT攻击

(四) OS可信增强软件

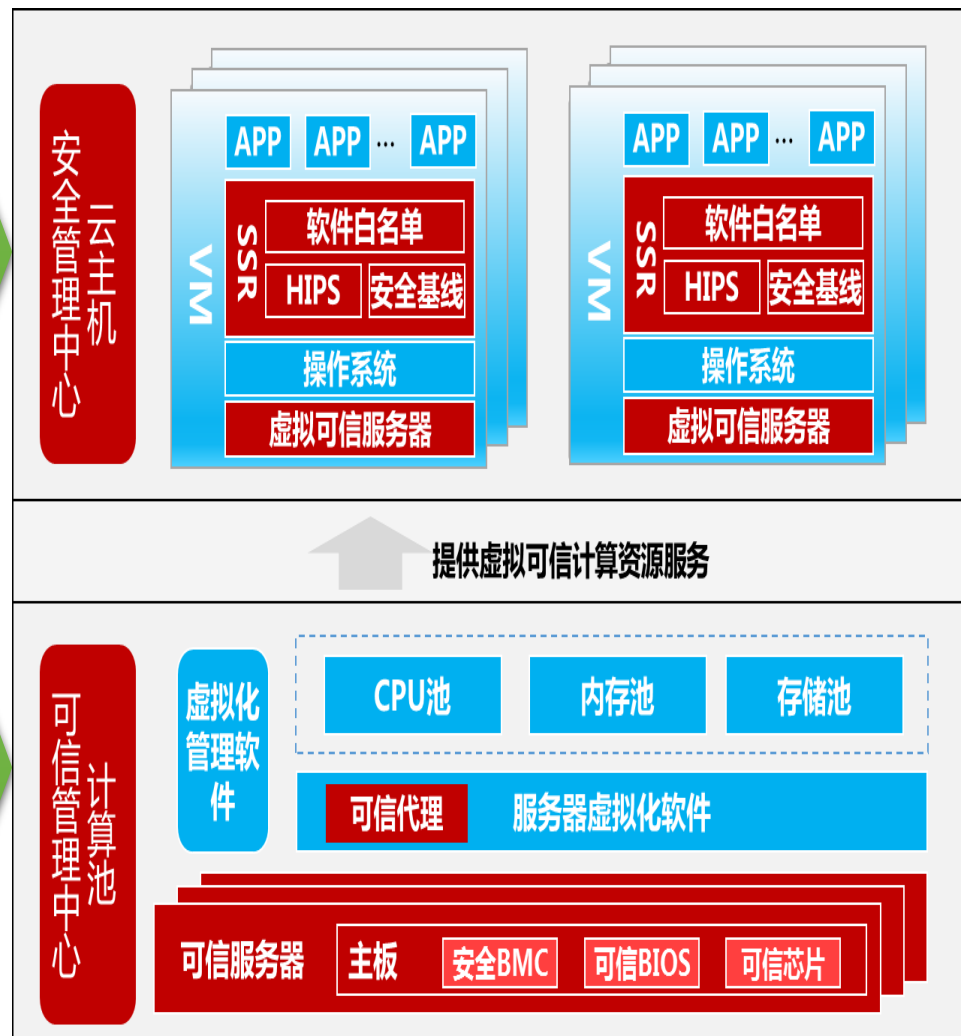
- Linux系统可信增强，实现软硬件计算平台可信

(五) 虚拟化可信套件

- 支持Xen、KVM虚拟化软件，实现虚拟机可信

安全云主机
解决方案

可信计算池
解决方案



软硬件一体化云计算安全整体解决方案——覆盖硬件/虚拟/OS

可信服务器——有效抵御硬件层面的APT攻击

浪潮2路可信服务器



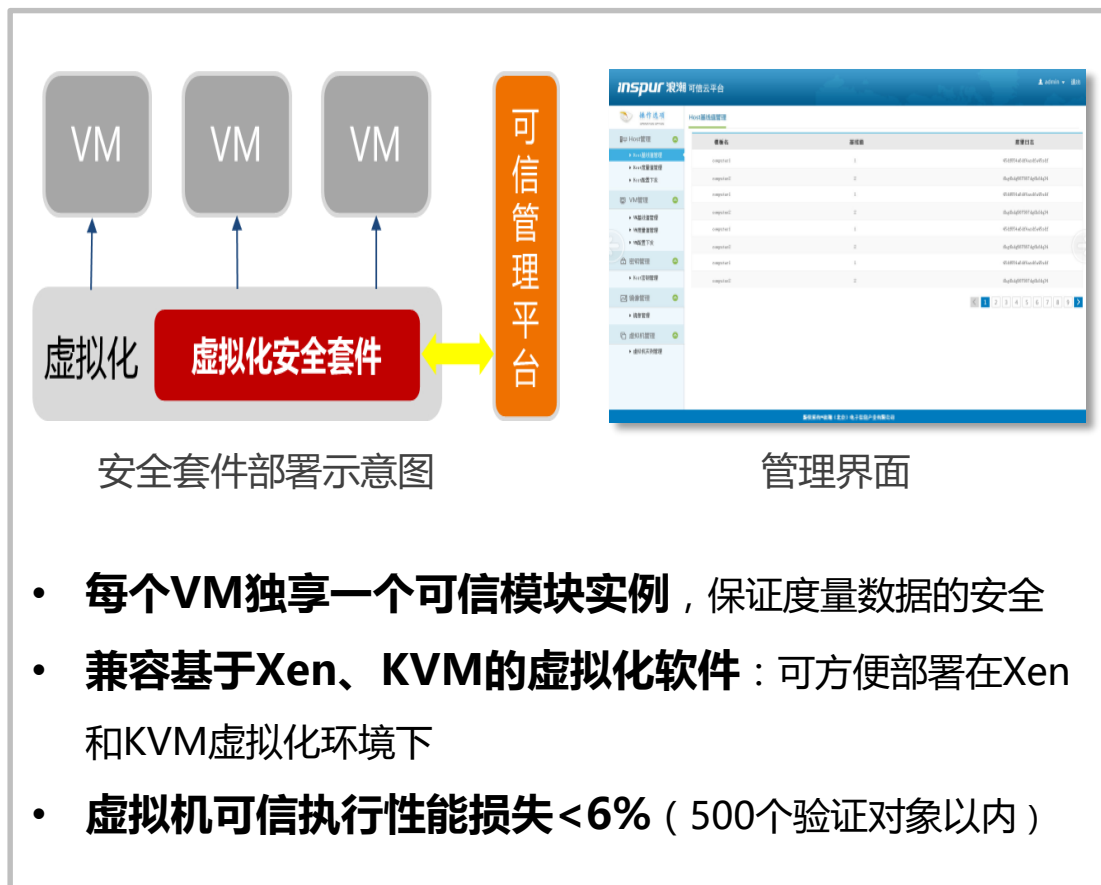
全自主研发，支持国产密码算法，
支持中标麒麟安全操作系统，兼容
Windows Server 2012、Windows
Server 2016，已批量供货

基于可信服务器的软硬一体化解决方案



- 可信增强软件
- 构建Linux环境下的可信计算平台解决方案
- 支持主流Linux平台下的可信平台迁移，已上市

虚拟化可信套件——打通虚拟化层，建立纵向信任链



虚拟机可信执行

虚拟机在启动时进行可信检查，防止被篡改的虚拟机启动

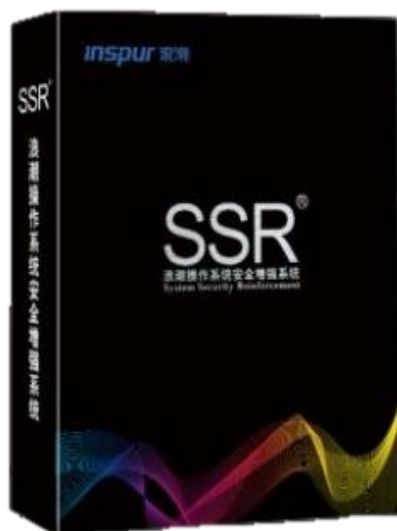
虚拟化软件可信启动

VMM在启动时，进行可信度量，防止虚拟机内核被篡改

镜像文件完整性保护

程序在启动时，进行可信度量，防止被篡改

SSR ——面向大中型企业，提供操作系统底层攻击防护



实现主流操作系统安全增强

- 2013年—2014年国内市场占有率第一
- 通过微软服务器操作系统认证和IBM AIX 服务器认证

覆盖主流操作系统

- 中标麒麟安全操作系统、Redhat、CentOS、SUSE
- Win2003、Win2008、Win2012
- AIX5.3、6.1
- HP-UX 11iv1、11iv2、11iv3
- Solaris 8、9、10

主要客户



奥运会



世博会



亚运会



全运会



大运会



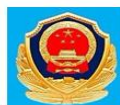
税务总局



海关总署



广电总局



公安部



计生委



工商总局



最高法院



新闻总署



海事局



中国石油

云戟——面向小微企业，提供免费网站安全利器



报告系统整体安全状态

保护系统，免疫系统木马

保护网站，免疫网站木马

防护任意希望保护的资源

发现和识别攻击来源

随时随地获得官方支持

支持系统：windows server 2003/2008/2012

攻击日益严重

网页被篡改

核心数据被盗取

流氓软件

服务器宕机

互联网小微企业

资金能力有限

技术实力薄弱

网站易遭受攻击

无法精准定位安全问题

云戟

一键搞定，漏洞无处藏

系统防护，网站防护

专属安全，特殊定制

专业团队，免费提供

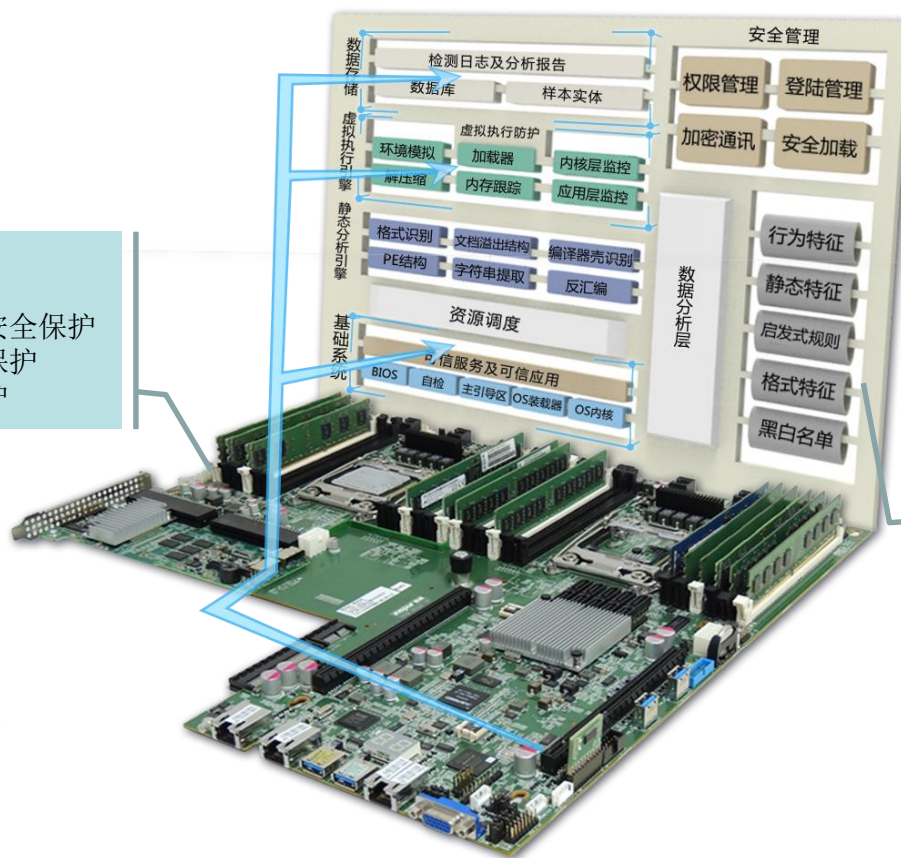
inspur 浪潮



ANTY 安天

浪潮可信计算平台

- ✓ 系统启动引导自验证安全保护
- ✓ 数据存储自验证安全保护
- ✓ 虚拟系统环境安全保护



安天追影威胁分析系统（可信版）

追影产品是在安天网络安全产品体系中的核心。

- 基于静动态结合的深度行为分析，对 APT 攻击具备出色的检测能力。
- 支持与网络安全产品联动，可改善安全网关、企业级安全防护产品的检测能力纵深。

浪潮可信服务器在商业银行的成功应用

客户需求

洛阳银行作为全国140余家城市商业银行和中小银行的典型代表，**将银行业信息科技重要业务系统移植到国产可信服务器上并确保业务安全、稳定的运行**，为商业银行逐步采用安全可控计算机设备起到典型示范作用。

方案价值

- 服务器采用浪潮2路可信服务器，部署可信增强软件实现硬件层、os kernel等可信度量，抵抗针对基础软硬件的高级别攻击能力。
- 在Linux系统部署浪潮SSR，增强操作系统安全性
- 可信服务器与城市商业银行主流操作系统，数据库及中间件的兼容性、可移植性，保证业务稳定性和高可用性。

方案介绍



某省警务云计算软硬件一体化安全保障

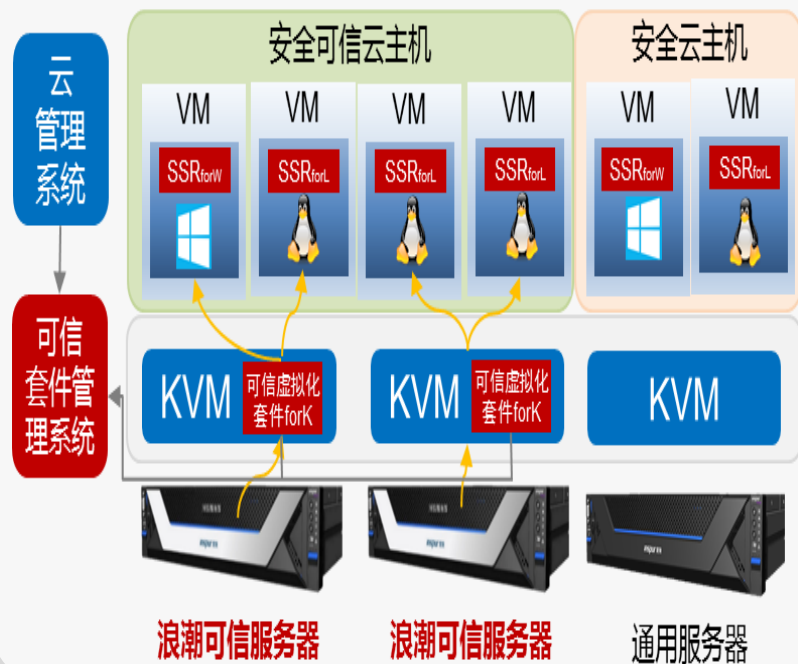
客户需求

- 增强云平台的安全性，以便增加客户采购云服务的安全信心
- 为客户提供增值的云主机安全可信服务

方案价值

- 服务器硬件采用**浪潮2路可信服务器**，在**KVM虚拟化软件中部署浪潮可信虚拟化套件**，保证云平台基础软硬件资源的可信性
- 在**VM中部署浪潮SSR**，对VM中OS的安全加固和可信支撑，为客户提供安全可信的运行环境，客户可及时了解平台可信状态
- 由**浪潮可信套件管理系统与云管理系统**协同，为客户VM可信性状态提供证明和管理。

方案介绍



Thanks



中国互联网安全大会



360互联网安全中心